AIORI-3 Hackathon

- **Problem Statement ID : PS-024**
- **Problem Statement Title- Privacy Pass Token Issuance and Anti-Replay Gateway**
- **Theme - CyberSecurity**
- **Institution - National Forensic Sciences University**
- **Team Name - GODSEC**
- **Team Code - A3-PS024-TC195**

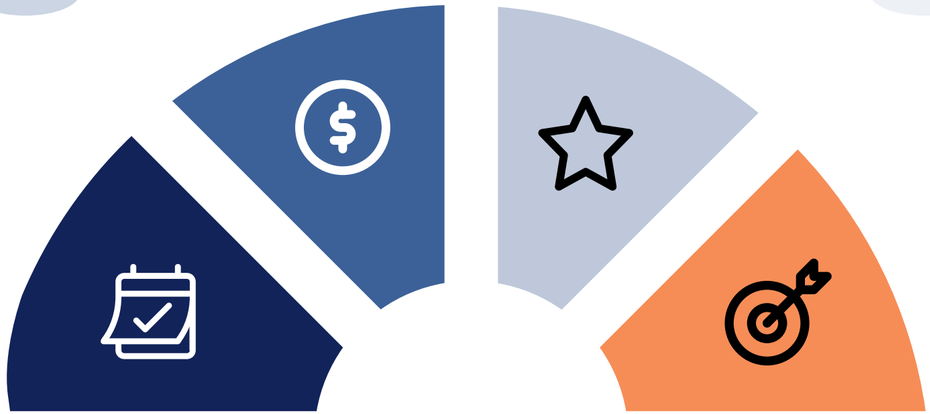
PROBLEM STATEMENT

CAPTCHA Fatigue & User Friction

When shared networks trigger automated anti-abuse thresholds, security systems force endless CAPTCHAs upon genuine human users, severely degrading web usability.

Surveillance & Tracking Trade-Off:

Traditional session tracking (cookies, persistent IP logging, device fingerprinting) protects web servers against bots at the direct expense of user anonymity and privacy.



Shared-IP Collateral Damage

Traditional IP-based rate-limiting and blocking rules treat all traffic from that IP as a single entity, unfairly locking out innocent users

The Missing Protocol Link:

Before Privacy Pass, web applications lacked a standardized, cryptographically sound mechanism to allow a client to prove they are a legitimate human without revealing their identity or browsing history.

The Shared-IP & CAPTCHA Dilemma in Web Security

“Modern web services face a severe structural conflict between enforcing strict anti-abuse defenses and preserving fundamental user privacy”.

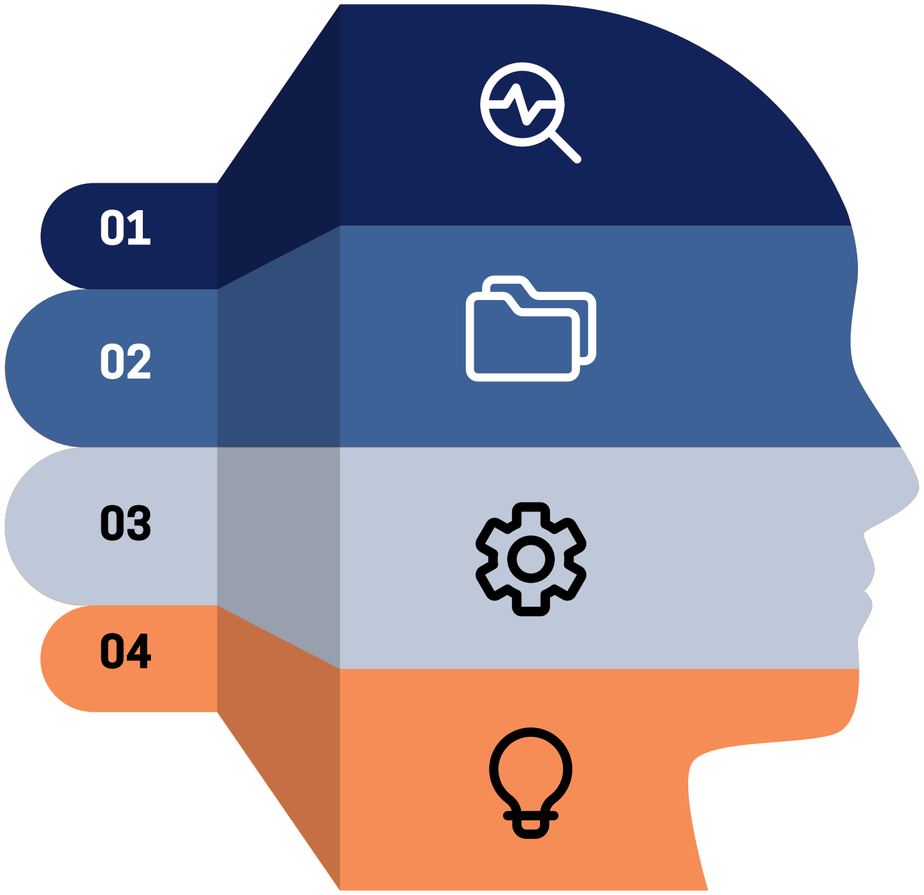
BACKGROUND:

Evolution of Web Anti-Abuse & Cryptographic Blinding



The Anti-Abuse Arms Race:

- Web security evolved from simple IP blocking ➔ User-Agent inspection ➔ JavaScript proof-of-work challenges ➔ invasive CAPTCHAs.
- Traditional defenses protect origin servers by imposing heavy friction on users, penalizing legitimate traffic sharing NAT/proxy boundaries.



The Cryptographic Breakthrough (Blind Signatures):

- Pioneered by David Chaum, blind signature schemes allow an authority (the Issuer) to cryptographically sign a blinded message without seeing its underlying content.
- This mathematically decouples issuance (proving you are human) from redemption (accessing the server), achieving absolute user unlinkability.

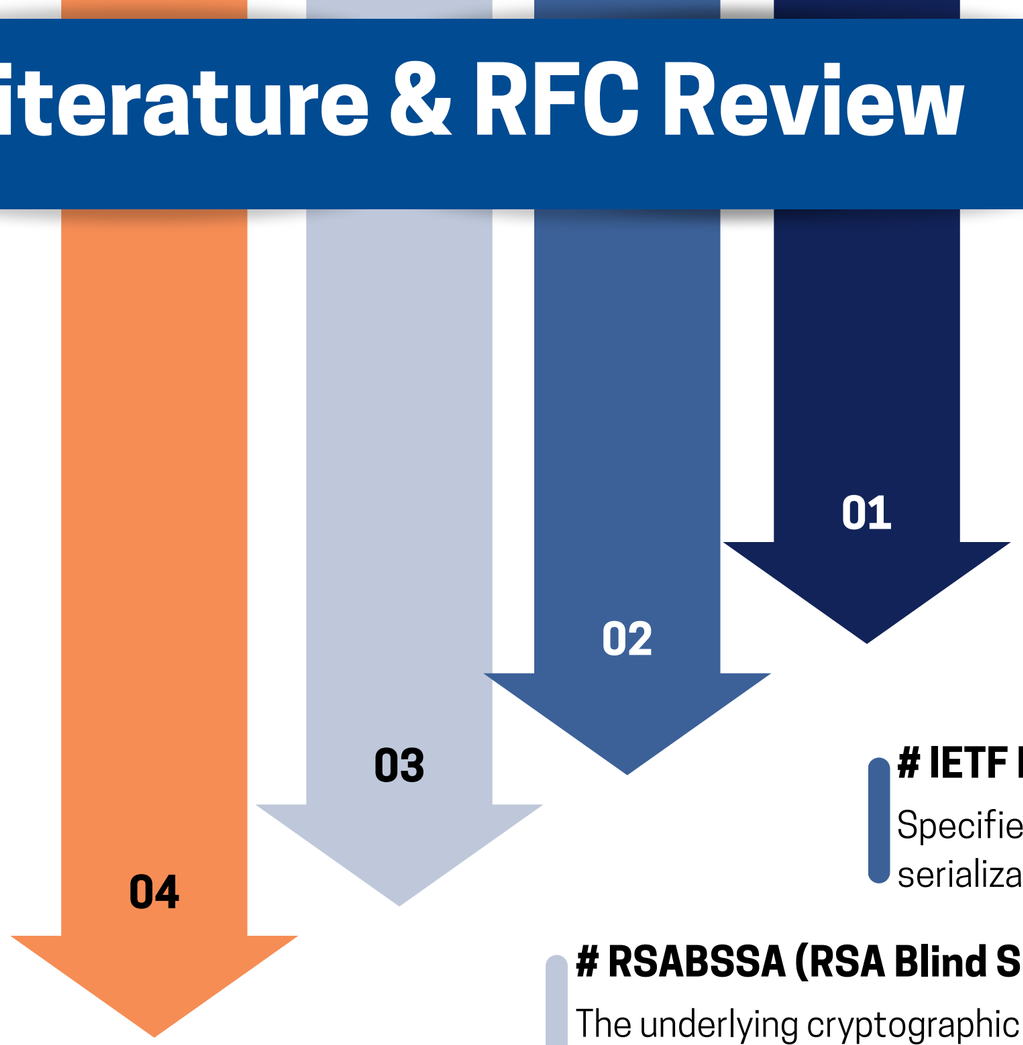
Modern Standardization (IETF RFC 9576 & RFC 9578):

- The Internet Engineering Task Force (IETF) standardized Privacy Pass protocols, defining standard HTTP authentication headers (Authorization: PrivateToken) and cryptographic suites (Blind RSA / VOPRF).

Our Proposed Optimization:

- Shifting from traditional stateful session tracking to stateless, edge-verified cryptographic tokens backed by an atomic, distributed Redis replay cache (SETNX) capable of sub-10ms validation at scale.

Literature & RFC Review



Foundational Protocols & RFCs

Our implementation is built strictly upon established IETF standards and foundational cryptographic research, ensuring interoperability and security compliance.

IETF RFC 9576 (The Privacy Pass HTTP Authentication Scheme): link

Defines the standardized HTTP authentication headers (Authorization: PrivateToken) and the 401 Challenge-Response handshake (issuer_url discovery).

IETF RFC 9578 (Privacy Pass Issuance Protocol): link

Specifies the protocol architecture for acquiring anonymous tokens, defining exact serialization structures for TokenRequest, TokenResponse, and token type registries.

RSABSSA (RSA Blind Signatures - PSS Deterministic Mode): link

The underlying cryptographic primitive utilizing RSA-PSS with SHA-384 hashing, enabling mathematical masking during issuance and public verification at the gateway.

Foundational Literature ("Blind Signatures for Untraceable Payments" — David Chaum, 1982): link

The seminal cryptographic paper establishing the mathematical principle of unlinkability, proving that a signer can endorse data without learning its contents.

PROPOSED SOLUTION

End-to-End Privacy Pass & High-Throughput Scalability

01 # Phase 0 & 1 (Blind Issuance Protocol):

- Clients complete attestation checks, cryptographically blind their token requests, and obtain RSA-PSS blind signatures from the Issuer—guaranteeing absolute unlinkability.

02 # Phase 2 (Stateless Edge Redemption & Verification):

- Gateways intercept unauthenticated requests with 401 Unauthorized challenges, verify incoming token signatures against the Issuer's public key, and achieve sub-10ms redemption latency.

03 # Atomic Anti-Replay Protection (SETNX):

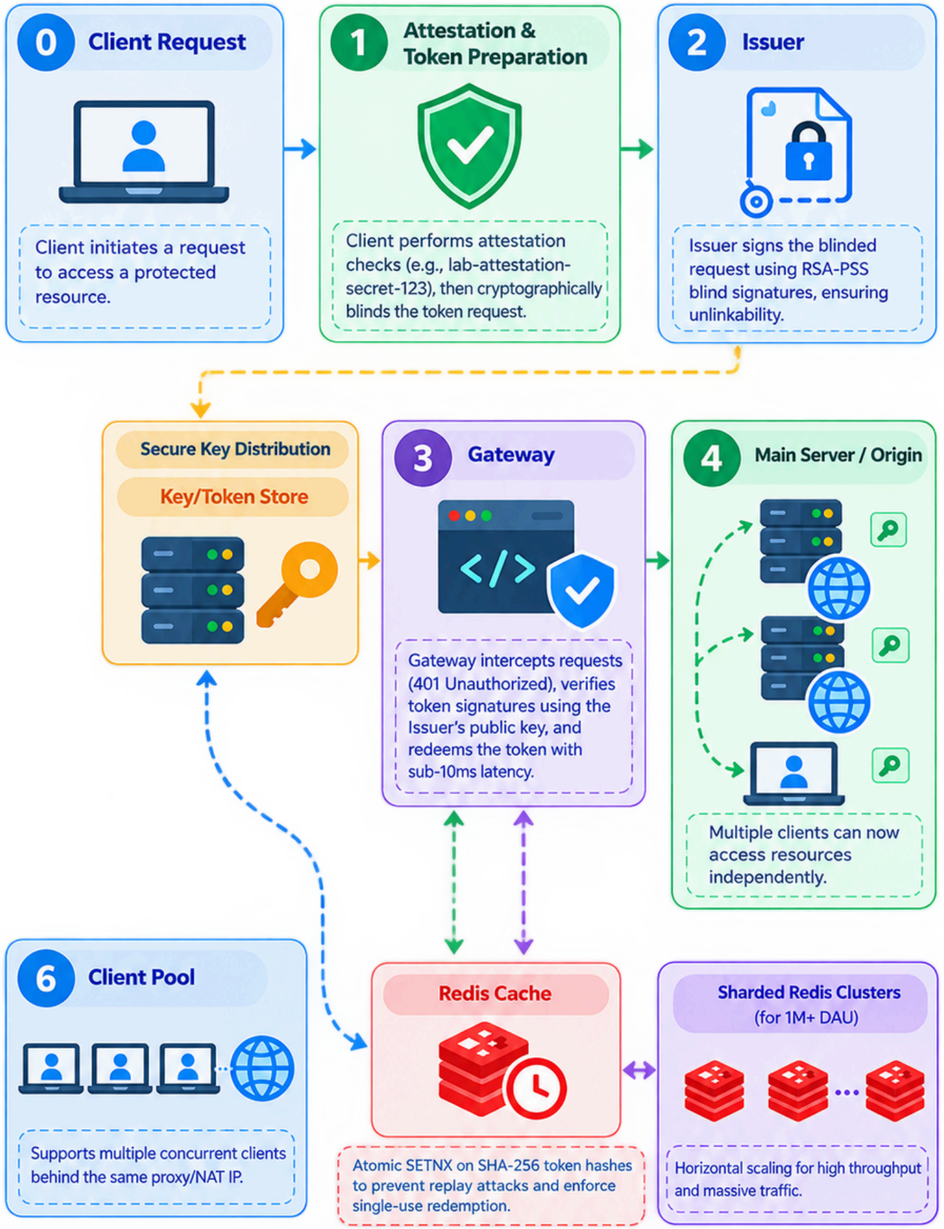
- Integrates an in-memory Redis cache using atomic SETNX operations over SHA-256 token hashes, enforcing single-use redemption and successfully blocking replay attacks.

04 # Shared-IP & NAT Resilience:

- Enables multiple concurrent clients (proven via our 50-client test suite) behind the exact same proxy or NAT IP address to authenticate independently using distinct cryptographic tokens

05 # High-Throughput Scalability & 1M DAU Architecture:

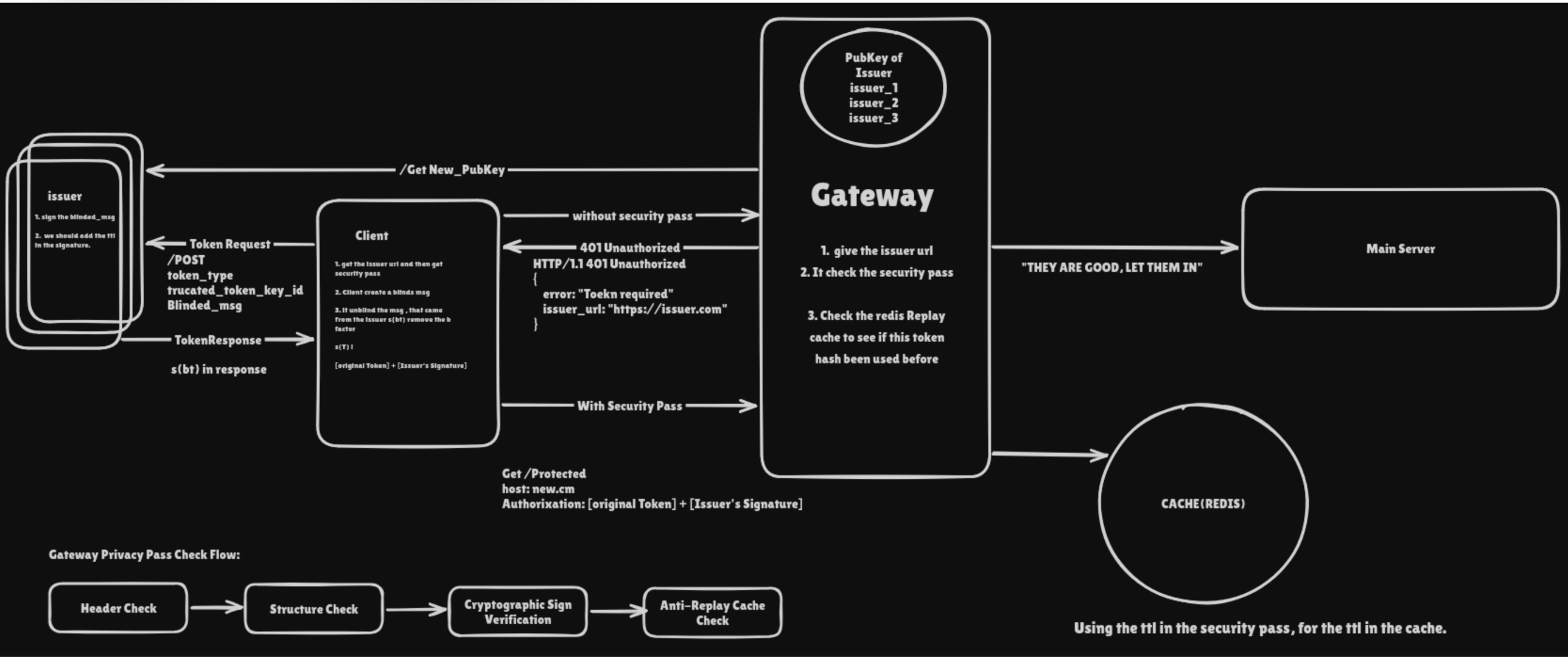
- Proven baseline performance of 735+ req/sec with ~9.99ms latency on a single core.
- Designed for horizontal scaling to 1M+ DAU via stateless edge gateways, in-memory public key caching, and sharded Redis clusters.



PROPOSED SOLUTION

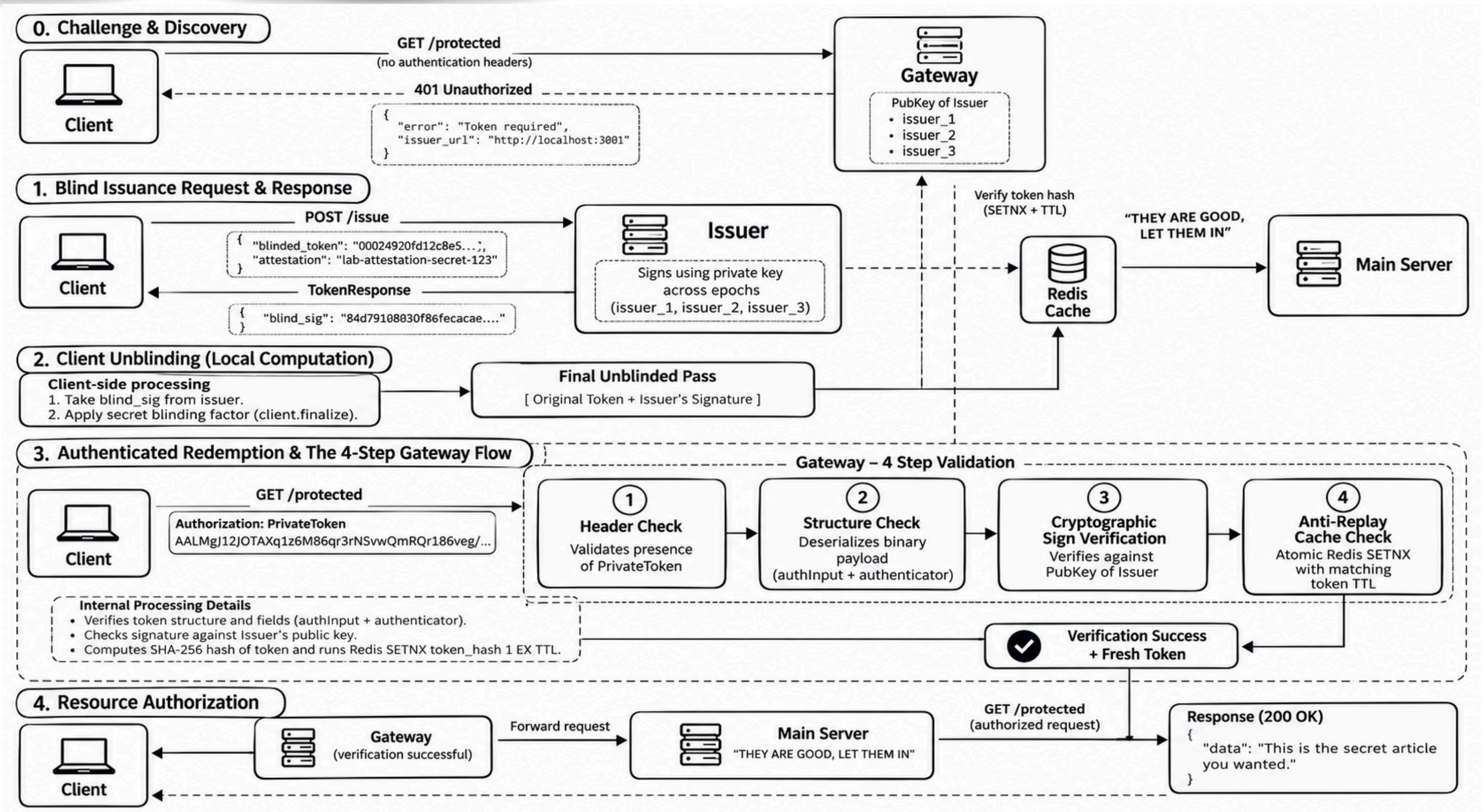
Evaluation Metric	Traditional Anti-Abuse (Before)	Optimized Privacy Pass (After - GODSEC)
User Friction	Endless CAPTCHAs triggered on shared IPs.	Zero friction (pre-issued token wallets redeem silently).
Shared-IP Handling	Blocks entire corporate/university NAT exits.	100% resilience (independent tokens per user behind same IP).
Redemption Latency	High (database lookups / session checks ~100ms+).	Lightning fast (~5.5ms to 9.99ms via Redis & edge verification).
User Privacy	Tracked via persistent cookies, IP, and fingerprinting.	Unlinkable anonymity (Issuer cannot link issuance to redemption).
Replay Prevention	Vulnerable or complex stateful session tracking.	Atomic & Scalable (Redis SHA-256 SETNX cache).

SYSTEM ARCHITECTURE



Architecture Overview: Our system architecture enforces a strict 3-phase lifecycle (Discovery ➔ Issuance ➔ Redemption) ensuring cryptographic isolation between identity, signing, and resource servers.

DATA FLOW Diagram



Deployment Timeline & Methodology

Deployment Timeline & Methodology: From Cryptographic Foundation to 1M DAU Scale

Methodology: Agile containerized microservice development utilizing Docker orchestration, automated test suites, and robust cryptographic key management.

Milestone 1

Cryptographic Foundation & Key Management (Completed)

- Implemented RSA-PSS 2048-bit key generation and JWK persistence (issuer-private-key.json, issuer-public-key.json).
- Engineered multi-instance rolling key structures (issuer_1, issuer_2, issuer_3) with JWKS keyring verification at the Gateway.

Milestone 2

Microservice Core Development (Completed)

- Built decoupled Express.js servers for the Issuer (Port 3001), Gateway (Port 3002), and Main Server / Origin (Port 3003).
- Implemented RFC 9576 challenge discovery (401 Unauthorized + issuer_url).

Milestone 3

Microservice Core Development (Completed)

- Integrated Redis-backed anti-replay protection using atomic SETNX operations over SHA-256 token hashes with dynamic TTLs matching token expiration.

Milestone 4

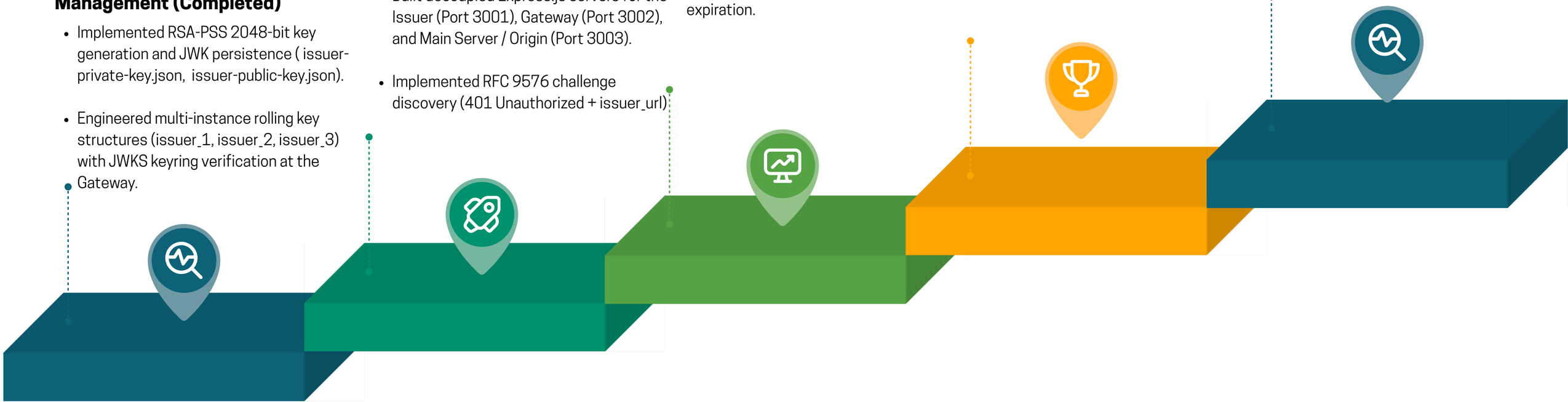
Test Suite & Shared-Proxy Validation (Completed)

- Developed and executed comprehensive test scripts (test-replay.js, test-invalid.js, test-wrong-context.js).

Milestore 5

Containerization & High-Throughput Benchmarking (Completed)

- Orchestrated full multi-service deployment via Docker and Docker Compose.
- Measured performance via load-test.js, achieving 735+ req/sec and ~9.99ms redemption latency.



Bibliography & References

1. IETF RFC 9576: The Privacy Pass HTTP Authentication Scheme. Internet Engineering Task Force (IETF), 2024.
   Available: https://datatracker.ietf.org/doc/rfc9576/
2. IETF RFC 9578: Privacy Pass Issuance Protocol. Internet Engineering Task Force (IETF), 2024.
   Available: https://datatracker.ietf.org/doc/rfc9578/
3. IETF RFC 9474: RSABSSA: RSA Blind Signatures. Internet Engineering Task Force (IETF), 2024.
   Available: https://datatracker.ietf.org/doc/rfc9474/
4. David Chaum: “Blind Signatures for Untractable Payments”. Advances in Cryptology: Proceedings of Crypto 82, pp. 199–203, 1982.
5. Cloudflare, Inc.: Privacy Pass & Blind RSA TypeScript Open-Source Libraries (@cloudflare/privacypass-ts, @cloudflare/blindsra-ts)
   Available: https://github.com/clouds/blindsra-ts